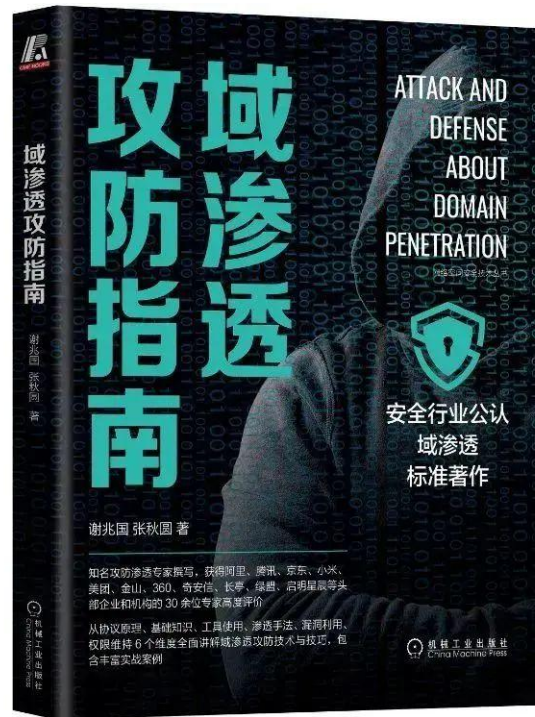


服务主体名称

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

SPN(ServicePrincipal Names)服务主体名称，是服务实例(如：HTTP、SMB、Exchange 等服务)的唯一标识符。Kerberos 身份验证使用 SPN 将服务实例与服务登录帐户相关联。如果在整个林或域中的计算机上安装多个服务实例，则每个实例都必须具有自己的 SPN。如果客户端使用多个名称进行身份验证，则给定服务实例可以具有多个 SPN。SPN 始终包含运行服务实例的主机名，因此服务实例可以为其主机的每个名称或别名注册 SPN。一个用户账户下可以有多个 SPN，但一

个 SPN 只能注册到一个账户。如果想使用 Kerberos 协议来认证服务，那么必须正确配置 SPN。

在 Kerberos 身份验证服务使用 SPN 对服务进行身份验证之前，必须在服务实例用于登录的帐户对象上注册 SPN。只能在一个帐户上注册给定的 SPN。对于 Win32 服务，服务安装程序在安装服务实例时指定登录帐户。然后，安装程序将编写 SPN，并作为帐户对象的属性写入 Active Directory 数据库中。如果服务实例的登录帐户发生更改，则必须在新帐户下重新注册 SPN。当客户端想要连接到某个服务时，它将查找该服务的实例，然后连接到该服务并显示该服务的 SPN 以进行身份验证。

在内网中，SPN 扫描通过查询向域控服务器执行服务发现。这对于红队而言，可以帮助他们识别正在运行重要服务的主机，如 Exchange 服务器等。SPN 的识别是 kerberoasting 攻击的第一步。

下面通过一个例子来说明 SPN 的作用：

Exchange 邮箱服务在安装的过程中，就会在活动目录中注册一个 Exchange 的 SPN。当用户需要访问 Exchange 邮箱服务时，系统会以当前用户的身份向域控查询 SPN 为 Exchange 的记录。当找到该 SPN 记录后，用户会再次与 KDC 通信，将 KDC 发放的 TGT 作为身份凭据发送给 KDC，并将需要访问的 SPN 发送给 KDC。KDC 中的 TGS 服务对 TGT 进行解密。确认无误后，由 TGS 将一张允许访问该 SPN 所对应的服务的 ST 服务票据和该 SPN 所对应的服务的地址发送给用户，用户使用该票据即可访问 Exchange 邮箱服务。

SPN 分为两种类型：

1. 一种是注册在活动目录的机器帐户(Computers)下，当一个服务的权限为 Local System 或 Network Service 时，则 SPN 注册在机器帐户(Computers)下。域中的每个机器账户都会注册两个 SPN：HOST/主机名和 HOST/主机名.xie.com

2. 另一种是注册在活动目录的域用户帐户(Users)下，当一个服务的权限为一个域用户，则 SPN 注册在域用户帐户下。

如图所示，可以看到机器 win2008 下注册的 SPN 和 hack 用户下注册的 SPN。

```
CN=WIN2008,CN=Computers,DC=xie,DC=com
WSMAN/Win2008
WSMAN/Win2008.xie.com
TERMSRV/WIN2008
TERMSRV/Win2008.xie.com
RestrictedKrbHost/WIN2008
HOST/WIN2008
RestrictedKrbHost/WIN2008.xie.com
HOST/WIN2008.xie.com
CN=hack,CN=Users,DC=xie,DC=com
SQLServer/win7.xie.com:1443/MSSQL
SQLServer/win7.xie.com:1433/MSSQL
```

这里以 SQLServer 服务注册为例：

SQLServer 在每次启动的时候，都会去尝试用自己的启动账号注册 SPN。但是在 Windows 域里，默认普通机器账号有权注册 SPN，但是普通域用户账号是没有权注册 SPN 的。这就会导致这样一个现象，SQL Server 如果使用“Local System account”来启动，Kerberos 就能够成功，因为 SQL Server 这时可以在 DC 上注册 SPN。如果用一个域用户来启动，Kerberos 就不能成功，因为这时 SPN 注册不上去。

解决办法：

- 可以使用工具 Setspn 来手动注册 SPN。但是这不是一个最好的方法，毕竟手工注册不是长久之计。如果 SPN 下次丢了，又要再次手动注册。

- 所以比较好的方法，是让 SQL Server 当前启动域账号有注册 SPN 的权力。要在 DC 上为域账号赋予“Read servicePrincipalName”和“Write serverPrincipalName”的权限即可。

SPN 的配置

SPN 在注册它的林中必须是唯一的。如果它不唯一，身份验证将失败。SPN 语法包含四个元素：两个必需的元素和两个其他元素，其中 和 为必须元素。如有必要，可以使用这些元素生成下表中列出的唯一名称。如下是 SPN 的格式：

<service **class**>/<host>:<port>/<service name>

- : 服务类，用于标识服务常规类的字符串;例如, "HOST"。有一些已知的服务类名称，例如 Web 服务的"WWW"或目录服务的"LDAP"。一般情况下，可以是服务类唯一的任何字符串。请注意，SPN 语法使用正斜杠 (/) 分隔元素，因此此字符不能出现在服务类名中。
- : 运行服务的计算机的名称。这可以是完全限定的 DNS 名称(FQDN)或 NetBIOS 名称。请注意，不确保 NetBIOS 名称在林中是唯一的，因此，包含 NetBIOS 名称的 SPN 可能不是唯一的。
- : 一个可选端口号，用于区分单个主计算机上同一服务类的多个实例。如果服务使用服务类的默认端口，则省略此组件。
- : 可复制服务 SPN 中使用的可选名称，用于标识服务或服务所服务的域提供的数据或服务。此组件可以具有以下格式之一：
 - 服务中对象的可分辨名称或 objectGUID Active Directory 域，例如 SCP (连接)。
 - 为整个域提供指定服务的域的 DNS 名称。
 - SRV 或 MX 记录的 DNS 名称。

1. 基于主机的服务

对于基于主机的服务，将省略"服务名称"组件，因为服务由服务类和安装该服务的主机名唯一标识。

```
<service class>/<host>
```

仅服务类就足以为客户端标识服务提供的功能。可以在多台计算机上安装服务类的实例，并且每个实例都提供使用其主计算机标识的服务。FTP 和 Telnet 是基于主机的服务的示例。如果服务使用非默认端口，或者主机上有多个服务实例，则基于主机的服务实例的 SPN 可以包含端口号。

```
<service class>/<host>:<port>
```

如下所示，是系统自动注册的基于主机服务的 SPN。

```
CN=WIN2008,CN=Computers,DC=xie,DC=com
WSMAN/Win2008
WSMAN/Win2008.xie.com
TERMSRV/WIN2008
TERMSRV/Win2008.xie.com
RestrictedKrbHost/WIN2008
HOST/WIN2008
RestrictedKrbHost/WIN2008.xie.com
HOST/WIN2008.xie.com
```

各个 SPN 代表的服务如下：

#Host 服务

HOST/WIN2008

HOST/WIN2008.xie.com

#RDP 服务

TERMSRV/WIN2008
TERMSRV/Win2008.xie.com

#WSMan/WinRM/PSRemoting 服务

WSMAN/Win2008
WSMAN/Win2008.xie.com

#RestrictedKrbHost 服务

RestrictedKrbHost/WIN2008
RestrictedKrbHost/WIN2008.xie.com

2. 可复制的服务

对于可复制服务，可以有一个或多个服务实例（副本），并且客户端不会区分它们连接到哪个副本，因为每个实例都提供相同的服务。每个副本的 SPN 具有相同的"服务类"和"服务名称"组件，其中"服务名称"更明确地标识服务提供的功能。只有和可选的组件因 SPN 而异。

<service **class**>/<host>:<port>/<service name>

可复制服务的一个示例是提供对指定数据库的访问的数据库服务的实例。在这种情况下，标识数据库应用程序，标识特定数据库。可以是包含数据库连接数据的 SCP 的可分辨名称。

MyDBService/host1.example.com/CN=hrdb,OU=mktg,DC=example,DC=com
MyDBService/host2.example.com/CN=hrdb,OU=mktg,DC=example,DC=com
MyDBService/host3.example.com/CN=hrdb,OU=mktg,DC=example,DC=com

可复制服务的另一个示例是向整个域提供服务。在这种情况下，组件是所服务的域的 DNS 名称。Kerberos KDC 是此类可复制服务的示例。

请注意，如果计算机的 DNS 名称发生更改，系统将更新林中该主机的所有已注册的 SPN 的元素。

使用 SetSPN 注册 SPN

在客户端使用 SPN 对服务实例进行身份验证之前，必须在服务实例上将用于登录的用户或计算机帐户注册 SPN。通常，SPN 注册由通过域管理员权限运行的服务安装程序来完成。但是我们也可以手动使用 Setspn.exe 程序来注册 SPN，setspn.exe 是 Windows 自带的一个二进制文件，该二进制文件可以用于 SPN 的查看、添加和删除。

如图所示，查看 setspn 的帮助说明。



```

c:\Users\hack\Desktop>setspn -h
Usage: setspn [modifiers switch] [accountname]
Where "accountname" can be the name or domain\name
of the target computer or user account

Edit Mode Switches:
-R = reset HOST ServicePrincipalName
Usage: setspn -R accountname
-S = add arbitrary SPN after verifying no duplicates exist
Usage: setspn -S SPN accountname
-D = delete arbitrary SPN
Usage: setspn -D SPN accountname
-L = list SPNs registered to target account
Usage: setspn [-L] accountname

Edit Mode Modifiers:
-C = specify that accountname is a computer account
-U = specify that accountname is a user account

Note: -C and -U are exclusive. If neither is specified, the tool
will interpret accountname as a computer name if such a computer
exists, and a user name if it does not.

Query Mode Switches:
-Q = query for existence of SPN
Usage: setspn -Q SPN
-X = search for duplicate SPNs
Usage: setspn -X

Note: searching for duplicates, especially forestwide, can take
a long period of time and a large amount of memory. -Q will execute
on each target domain/forest. -X will return duplicates that exist
across all targets. SPNs are not required to be unique across forests,
but duplicates can cause authentication issues when authenticating
cross-forest.

Query Mode Modifiers:
-P = suppresses progress to the console and can be used when redirecting
output to a file or when used in an unattended script. There will be no
output until the command is complete.
-F = perform queries at the forest, rather than domain level
-T = perform query on the specified domain or forest (when -F is also used)
Usage: setspn -T domain (switches and other parameters)
"" or * can be used to indicate the current domain or forest.

Note: these modifiers can be used with the -S switch in order to specify
where the check for duplicates should be performed before adding the SPN.
Note: -T can be specified multiple times.

```

我们可以使用 `-S` 参数来注册 SPN。

1. 如果是注册在域用户下，还可以使用 `-U -A` 参数注册

2. 如果是注册在机器用户下，可以使用-C -A 参数注册

1. SPN 注册权限

只有机器账号或域管理员账号有权限注册 SPN，普通域用户注册 SPN 会提示特权不够，不能执行该操作。而使用机器账号注册 SPN 时，注册的 SPN 的必须为当前主机的 DNS 名称。使用域管理员账号注册 SPN 无任何限制！

如图所示，通过切换到本地 System 权限窗口来使用机器账号注册 SPN，注册的 SPN 的为当前主机的 DNS 名称。

```
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>setspn -S MySQL/win7.xie.com:3306 win7
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=WIN7,CN=Computers,DC=xie,DC=com
MySQL/win7.xie.com:3306
Updated object
```

如果使用机器账号注册 SPN，注册的 SPN 的不为当前主机的 DNS 名称，会提示失败。如图所示：

```
C:\Windows\system32>hostname
win7
使用System权限注册非本地Host的SPN会失败

C:\Windows\system32>setspn -S MySQL/win2008.xie.com:3306 win2008
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=WIN2008,CN=Computers,DC=xie,DC=com
MySQL/win2008.xie.com:3306
Failed to assign SPN on account 'CN=WIN2008,CN=Computers,DC=xie,DC=com', error 0x
2098/8344 -> Insufficient access rights to perform the operation.
```

使用普通域用户执行如下命令注册 SPN，由于权限不足，所以提示失败！

```
setspn -S MySQL/win7.xie.com:3306 hack
```

如图所示，使用普通域用户注册 SPN。

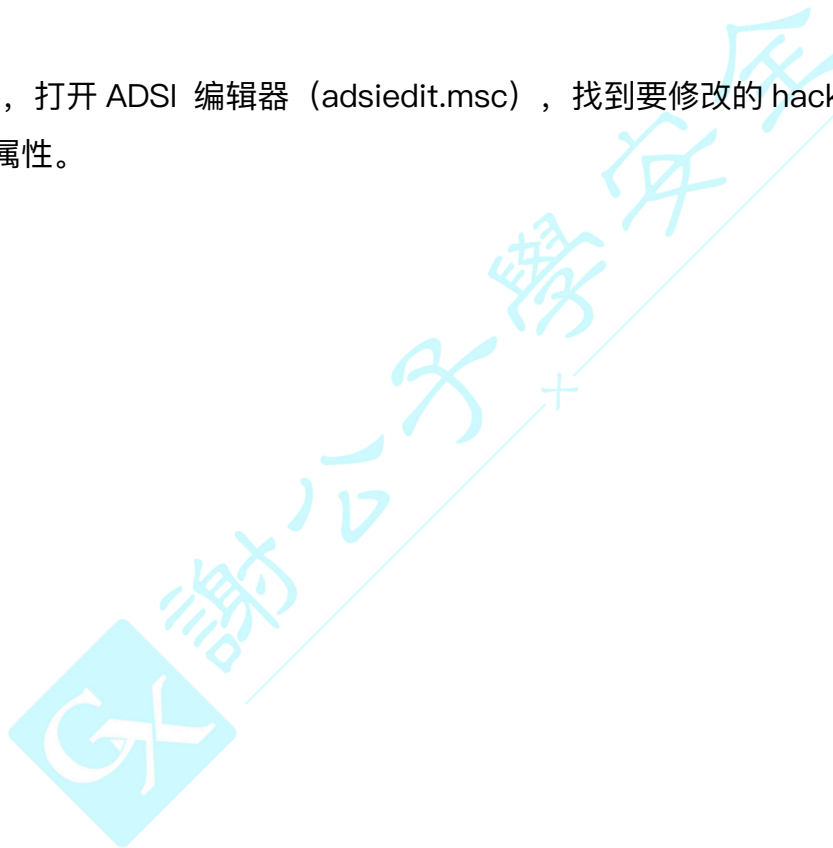
```
C:\Users\hack>whoami
xie\hack

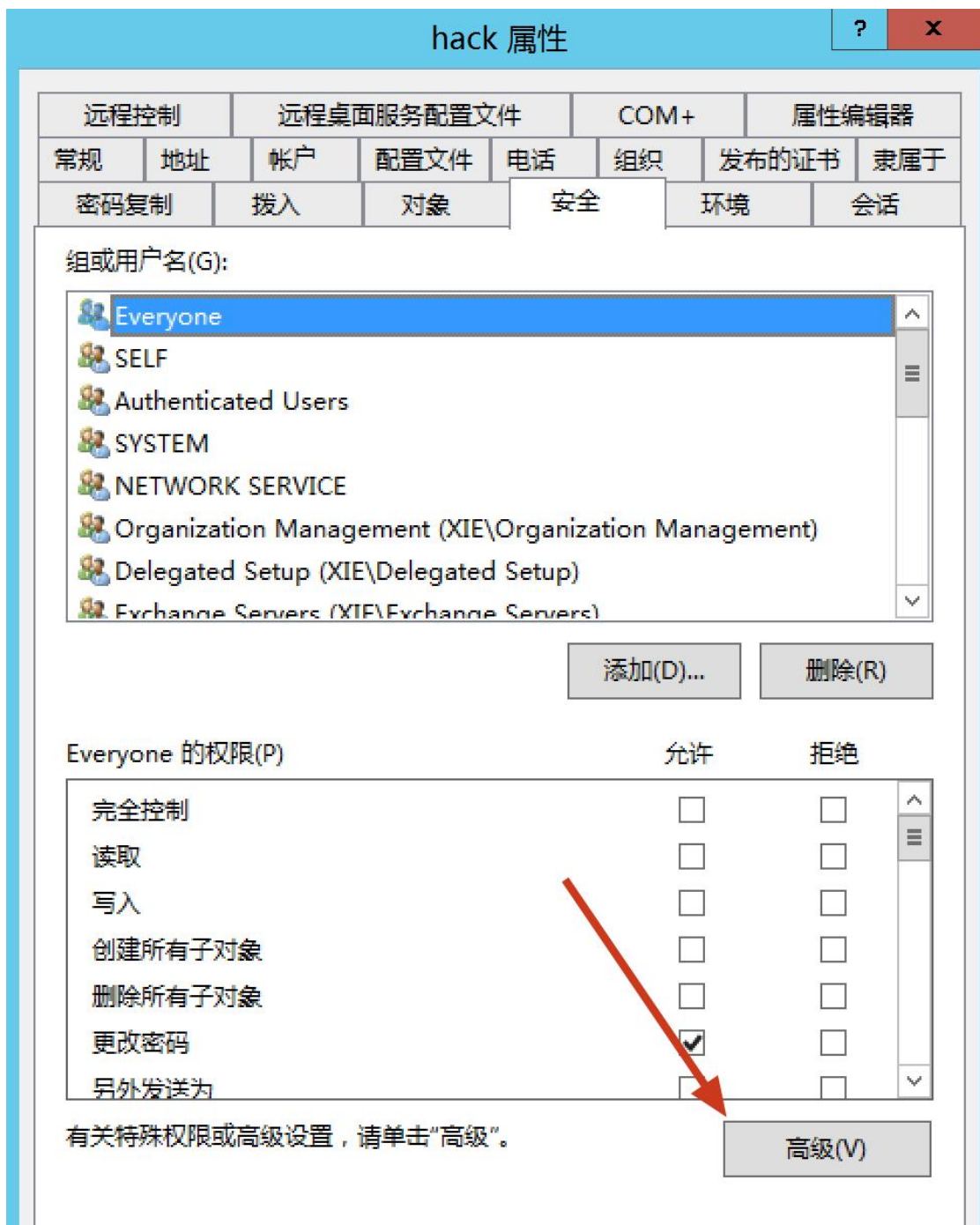
C:\Users\hack>setspn -S MySQL/win7.xie.com:3306 hack
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com
MySQL/win7.xie.com:3306
Failed to assign SPN on account 'CN=hack,CN=Users,DC=xie,DC=com', error 0x2098/8344 -> Insufficient access rights to
perform the operation.
```

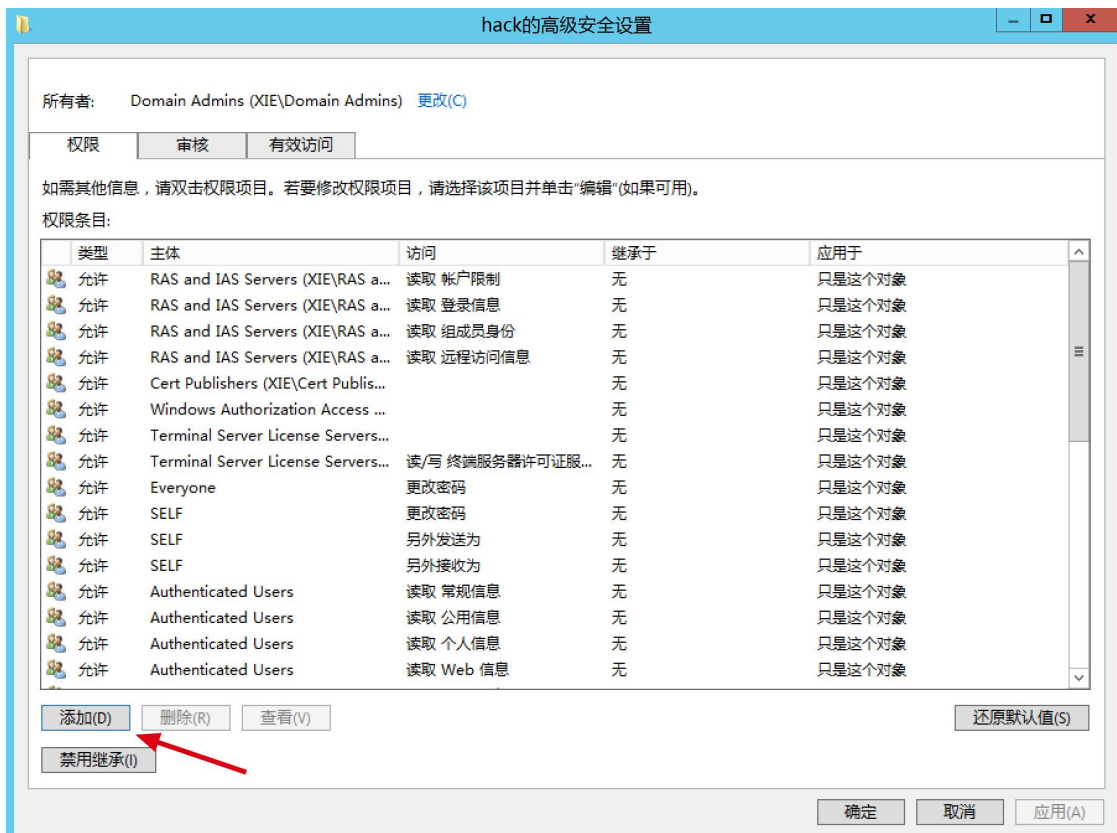
如果想让普通域用户也拥有注册 SPN 权限的话，需要在域控上手动为域账号赋予“读取 servicePrincipalName”和“写入 serverPrincipalName”的权限。具体操作如下：

如图所示，打开 ADSI 编辑器（adsiedit.msc），找到要修改的 hack 用户，右键——>属性。

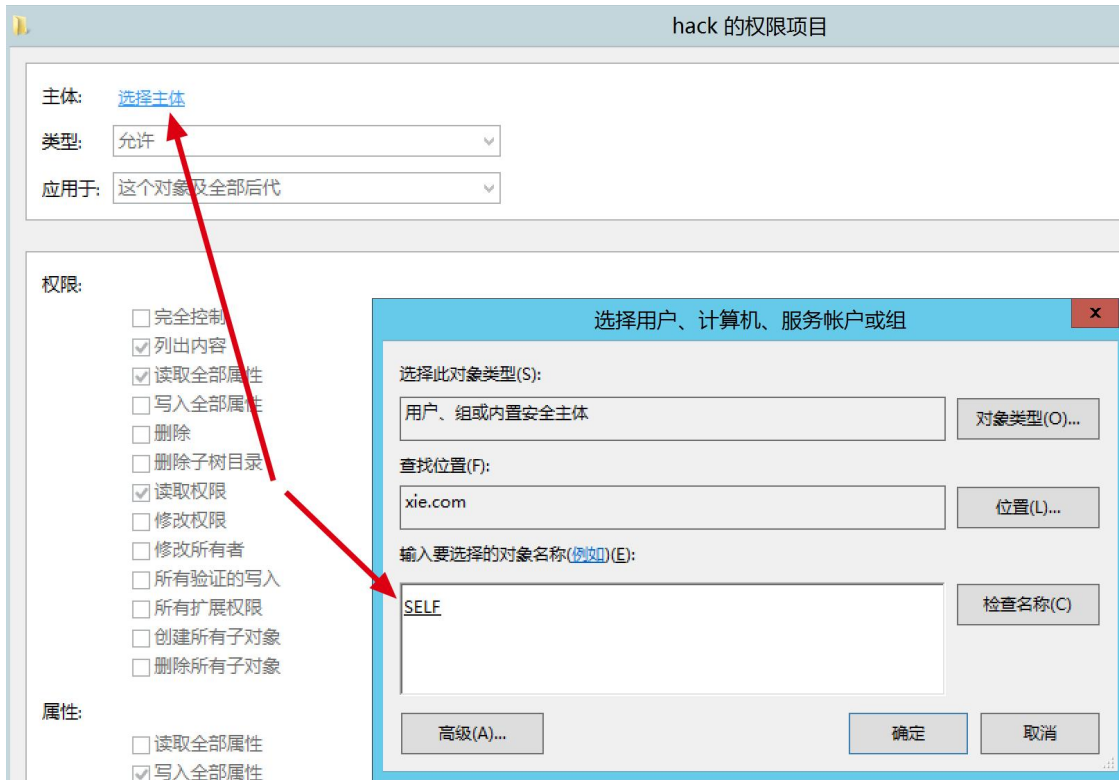




然后点击添加，如图所示：



点击选择主体, 然后输入 SELF。如图所示:



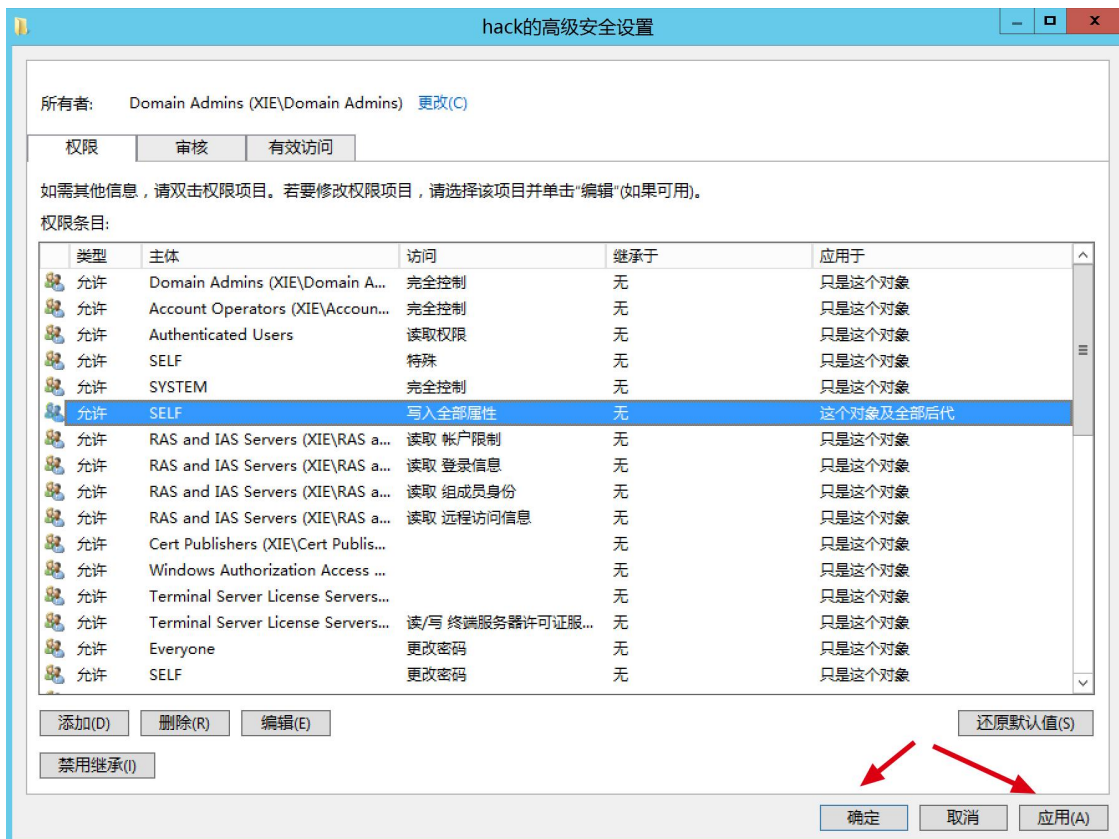
接着勾选“读取 servicePrincipalName”和“写入 serverPrincipalName”选项。
如图所示：



hack 的权限项目

☒ 写入 msCOM-PartitionSetLink	☐ 读取 sDRightsEffective
☐ 读取 msCOM-UserLink	☒ 写入 sDRightsEffective
☒ 写入 msCOM-UserLink	☐ 读取 secretary
☐ 读取 msCOM-UserPartitionSetLink	☒ 写入 secretary
☒ 写入 msCOM-UserPartitionSetLink	☐ 读取 securityIdentifier
☐ 读取 msDFSR-ComputerReferenceBL	☒ 写入 securityIdentifier
☒ 写入 msDFSR-ComputerReferenceBL	☐ 读取 seeAlso
☐ 读取 msDFSR-MemberReferenceBL	☒ 写入 seeAlso
☒ 写入 msDFSR-MemberReferenceBL	☐ 读取 serialNumber
☐ 读取 msDRM-IdentityCertificate	☒ 写入 serialNumber
☒ 写入 msDRM-IdentityCertificate	☐ 读取 serverReferenceBL
☐ 读取 msDS-AllowedToActOnBehalfOfOtherIdentity	☒ 写入 serverReferenceBL
☒ 写入 msDS-AllowedToActOnBehalfOfOtherIdentity	☒ 读取 servicePrincipalName
☐ 读取 msDS-AllowedToDelegateTo	☒ 写入 servicePrincipalName
☒ 写入 msDS-AllowedToDelegateTo	☐ 读取 shadowExpire
☐ 读取 msDS-Approx-Immed-Subordinates	☒ 写入 shadowExpire
☒ 写入 msDS-Approx-Immed-Subordinates	☐ 读取 shadowFlag
☐ 读取 msDS-AssignedAuthNPolicy	☒ 写入 shadowFlag

然后应用、确定即可。如图所示：



然后就可以使用普通域用户注册 SPN 了。执行如下命令在 hack 域账号下注册 SPN。

```
setspn -S MySQL/win7.xie.com:3306 hack
```

如图所示, 可以看到 hack 用户成功注册 SPN。

```

C:\Users\hack>whoami
xie\hack

C:\Users\hack>hostname
Server2016

C:\Users\hack>setspn -S MySQL/win7.xie.com:3306 hack
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com
MySQL/win7.xie.com:3306
Updated object

```

但是即使为域账号了赋予“Read servicePrincipalName”和“Write serverPrincipalName”的权限，当前账户也只能将 SPN 注册在当前用户下，而无法注册在其他用户下。

如图所示，hack 用户将 SPN 注册于其它用户下，提示权限拒绝。

```

C:\Users\hack>whoami
xie\hack

C:\Users\hack>setspn -S MySQL/win7.xie.com:3307 test
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=test,CN=Users,DC=xie,DC=com
MySQL/win7.xie.com:3307
Failed to assign SPN on account 'CN=test,CN=Users,DC=xie,DC=com', error 0x2098/8344 -> Insufficient access rights to
perform the operation.

```

以下我们注册 SPN 均是在域管理员 administrator 身份下进行注册。

2. 将 SPN 注册在域账号下

运行如下命令使用 -S 参数或 -U -S 参数将 SPN 注册在域用户 hack 下：

```
setspn -S SQLServer/win7.xie.com:1433/MSSQL hack
```

或

```
setspn -U -S SQLServer/win7.xie.com:1443/MSSQL hack
```

#查询 hack 用户注册的 SPN

```
setspn -L hack
```

如图所示，使用不同命令将 SPN 注册于 hack 用户下。

```
C:\Users\Administrator\Desktop>setspn -S SQLServer/win7.xie.com:1433/MSSQL hack
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com
SQLServer/win7.xie.com:1433/MSSQL
Updated object

C:\Users\Administrator\Desktop>setspn -U -S SQLServer/win7.xie.com:1443/MSSQL hack
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com
SQLServer/win7.xie.com:1443/MSSQL
Updated object

C:\Users\Administrator\Desktop>setspn -L hack
Registered ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com:
SQLServer/win7.xie.com:1443/MSSQL
SQLServer/win7.xie.com:1433/MSSQL
```

3. 将 SPN 注册在机器账号下

运行如下命令使用-S 参数或-C -S 参数将 SPN 注册在机器账号 win7 下：

```
setspn -S SQLServer/win7.xie.com:1433/MSSQL win7
```

或

```
setspn -C -S SQLServer/win7.xie.com:1443/MSSQL win7
```

#查询 win7 机器注册的 SPN

```
setspn -L win7
```

如图所示，使用不同命令将 SPN 注册于机器账号 win7 下。

```

C:\Users\Administrator>setspn -S SQLServer/win7.xie.com:1433/MSSQL win7
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=WIN7,CN=Computers,DC=xie,DC=com
SQLServer/win7.xie.com:1433/MSSQL
Updated object

C:\Users\Administrator>setspn -C -S SQLServer/win7.xie.com:1443/MSSQL win7
Checking domain DC=xie,DC=com

Registering ServicePrincipalNames for CN=WIN7,CN=Computers,DC=xie,DC=com
SQLServer/win7.xie.com:1443/MSSQL
Updated object

C:\Users\Administrator>setspn -L win7
Registered ServicePrincipalNames for CN=WIN7,CN=Computers,DC=xie,DC=com:
SQLServer/win7.xie.com:1443/MSSQL
SQLServer/win7.xie.com:1433/MSSQL
RestrictedKrbHost/WIN7
HOST/WIN7
RestrictedKrbHost/WIN7.xie.com
HOST/WIN7.xie.com

```

SPN 的查询和发现

由于每台服务器都需要注册用于 Kerberos 身份验证服务的 SPN，因此这为在不进行大规模端口扫描的情况下收集有关内网域环境的信息提供了一个更加隐蔽的方法。

如下使用不同的工具探测域内的 SPN：

1. setspn

可以通过 Windows 系统自带的 setspn 执行如下命令查询域内的 SPN。

#查看当前域内所有的 SPN

```
setspn -Q */*
```

#如果在域林中，则可以使用如下命令查看指定域 xie.com 内的 SPN。如果指定域不存在，则默认切换到查找本域的 SPN

```
setspn -T xie.com -Q */*
```

#查找本域内重复的 SPN

```
setspn -X
```

#删除指定 SPN:

```
setspn -D MySQL/win7.xie.com:1433/MSSQL hack
```

#查找指定用户/主机名注册的 SPN

```
setspn -L username/hostname
```

如图所示，查询域内所有的 SPN。

```
C:\Users\hack>setspn -Q */*
Checking domain DC=xie,DC=com
CN=AD01,OU=Domain Controllers,DC=xie,DC=com
Dfsr-12F9A27C-BF97-4787-9364-D31B6C55EB04/AD01.xie.com
ldap/AD01.xie.com/ForestDnsZones.xie.com
ldap/AD01.xie.com/DomainDnsZones.xie.com
DNS/AD01.xie.com
GC/AD01.xie.com/xie.com
RestrictedKrbHost/AD01.xie.com
RestrictedKrbHost/AD01
RPC/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
HOST/AD01/XIE
HOST/AD01.xie.com/XIE
HOST/AD01
HOST/AD01.xie.com
HOST/AD01.xie.com/xie.com
E3514235-4B06-11D1-AB04-00C04FC2DCD2/488c533a-cddd-4cee-869a-c8a4efb7fc9a/xie.com
ldap/AD01/XIE
ldap/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
ldap/AD01.xie.com/XIE
ldap/AD01
ldap/AD01.xie.com
ldap/AD01.xie.com/xie.com
CN=krbtgt,CN=Users,DC=xie,DC=com
kadmin/changepw
```

如图所示，查询注册于 hack 用户和 win7 机器帐户下的 SPN。


```
C:\Users\hack>setspn -L hack
Registered ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com:
    SQLServer/win7.xie.com:1453/MSSQL

C:\Users\hack>setspn -L win7
Registered ServicePrincipalNames for CN=WIN7,CN=Computers,DC=xie,DC=com:
    SQLServer/win7.xie.com:1443/MSSQL
    SQLServer/win7.xie.com:1433/MSSQL
    RestrictedKrbHost/WIN7
    HOST/WIN7
    RestrictedKrbHost/WIN7.xie.com
    HOST/WIN7.xie.com
```

2. impacket

impacket 中的 GetUserSPNs.py 脚本可以在域外查询指定域的 SPN，使用该脚本只需要提供一个有效的域凭据。

使用 GetUserSPNs.py 脚本执行如下命令查询域控 10.211.55.4 所在的域内注册于用户下的 SPN。

```
python3 GetUserSPNs.py -dc-ip 10.211.55.4 xie.com/hack:P@ss1234
```

如图所示，查询到注册域用户下的 SPN 两 2 个，分别为 MySQL/win7.xie.com:3306 和 SQLServer/win7.xie.com:1533/MSSQL。

```
~/impacket/examples  master  python3 GetUserSPNs.py -dc-ip 10.211.55.4 xie.com/hack:P@ss1234
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
MySQL/win7.xie.com:3306	hack		2021-09-13 10:01:35.300783	2021-09-14 16:30:24.060875	
SQLServer/win7.xie.com:1533/MSSQL	test		2021-08-20 09:36:27.110746	2021-09-14 14:19:21.788170	

3. PowerShellery

PowerShellery 下有各种各样针对服务 SPN 探测的脚本。其中一些只需要 PowerShell v2.0 的环境，而有一些则需要 PowerShell v3.0 环境。如下是 PowerShellery 下不同脚本的使用：

#PowerShellery/Stable-ish/Get-SPN/ 下 Get-SPN.psm1 脚本的使用,需要 powershell 3.0 及以上版本才能使用

```
Import-Module .\Get-SPN.psm1
```

```
Get-SPN -type service -search "*"
```

```
Get-SPN -type service -search "*" -List yes | Format-Table
```

#Powershellery/Stable-ish/ADS/ 下 Get-DomainSpn.psm1 脚本的使用

```
Import-Module .\Get-DomainSpn.psm1
```

```
Get-DomainSpn
```

如图所示，使用 Get-SPN.psm1 脚本查询域内所有的 SPN。

```
PS C:\Users\hack\Desktop> Import-Module .\Get-SPN.psm1
PS C:\Users\hack\Desktop> Get-SPN -type service -search "*"

Name           : AD01
SAMAccount     : AD01$
Description    :
UserPrincipal  :
DN             : CN=AD01,OU=Domain Controllers,DC=xie,DC=com
Created        : 2021/2/27 12:41:36
LastModified   : 2021/9/13 2:00:05
PasswordLastSet : 2021/8/20 9:35:08
AccountExpires : <Never>
LastLogon      : 2021/9/13 11:02:27
GroupMembership :
SPN Count      : 20

ServicePrincipalNames (SPN):
Dfsr-12F9A27C-BF97-4787-9364-D31B6C55EB04/AD01.xie.com
ldap/AD01.xie.com/ForestDnsZones.xie.com
ldap/AD01.xie.com/DomainDnsZones.xie.com
DNS/AD01.xie.com
GC/AD01.xie.com/xie.com
RestrictedKrbHost/AD01.xie.com
RestrictedKrbHost/AD01
RPC/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
HOST/AD01/XIE
HOST/AD01.xie.com/XIE
HOST/AD01
HOST/AD01.xie.com
HOST/AD01.xie.com/xie.com
E3514235-4B06-11D1-AB04-00C04FC2DCD2/488c533a-cddd-4cee-869a-c8a4efb7fc9a/xie.com
ldap/AD01/XIE
ldap/488c533a-cddd-4cee-869a-c8a4efb7fc9a._msdcs.xie.com
```

4. PowerShell-AD-Recon

该工具包提供了一些发现指定 SPN 的脚本，例如指定 Exchange，Microsoft SQLServer 等服务的 SPN。但其实对于 Kerberoasting 攻击第一步 SPN 的发现意义不大，因为该脚本并没过滤出注册于域用户下的 SPN。

如下是 不同脚本的使用。

#探测域内注册的 SQLServer 服务的 SPN

```
Import-Module .\Discover-PSMSSQLServers.ps1;  
Discover-PSMSSQLServers
```

#探测域内注册的 Exchange 服务的 SPN

```
Import-Module .\Discover-PSMSEExchangeServers.ps1;  
Discover-PSMSEExchangeServers
```

#扫描域中所有的 SPN 信息

```
Import-Module .\Discover-PSInterestingServices.ps1;  
Discover-PSInterestingServices
```

如图所示，是 PowerShell-AD-Recon 中不同脚本的使用。



```
PS C:\Users\hack\Desktop> Import-Module .\Discover-PSMSSQLServers.ps1;
PS C:\Users\hack\Desktop> Discover-PSMSSQLServers
Processing 0 (user and computer) accounts with MS SQL SPNs discovered in AD Forest DC=xie,DC=com
PS C:\Users\hack\Desktop> Import-Module .\Discover-PSMSEExchangeServers.ps1;
PS C:\Users\hack\Desktop> Discover-PSMSEExchangeServers
Processing 0 (user and computer) accounts with MS Exchange SPNs discovered in AD Forest DC=xie,DC=com
PS C:\Users\hack\Desktop> Import-Module .\Discover-PSInterestingServices.ps1;
PS C:\Users\hack\Desktop> Discover-PSInterestingServices
警告: Unable to gather property data for computer
警告: Unable to gather property data for computer

Domain          : xie.com
ServerName       : Server2016.xie.com
SPNServices      : WSMAN
OperatingSystem  : {Windows Server 2016 Datacenter}
OSServicePack    :
LastBootup       : 2021/9/13 10:31:19
OSVersion        : {10.0 (14393)}
Description      :

Domain          : _msdcs.xie.com
ServerName       : _msdcs.xie.com\DNSzone
SPNServices      : ldap
OperatingSystem  : {Windows Server 2016 Datacenter}
OSServicePack    :
LastBootup       : 2021/9/13 10:31:19
OSVersion        : {10.0 (14393)}
Description      :
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。





谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



参考文章：

<https://docs.microsoft.com/zh-cn/windows/win32/ad/service-principal-names>

<https://docs.microsoft.com/zh-cn/windows/win32/ad/how-a-service-registers-its-spn>

